

Bypassing Android Password Manager Apps Without Root

Stephan Huber, Siegfried Rasthofer, Steven Arzt

Fraunhofer SIT



Stephan

- Mobile Security Researcher at Fraunhofer SIT
- Enjoys teaching students in Android (app) hacking
- Twitter: @teamsik

Siegfried

- Head of Department Secure Software Engineering at Fraunhofer SIT
- Founder of CodeInspect
- Web: www.rasthofer.info
- Twitter: @teamsik



Acknowledgements

- Benedikt Hiemenz
- Daniel Hitzel
- Daniel Magin
- Joseph Varghese
- Julien Hachenberger
- Max Kolhagen
- Michael Tröger
- Philipp Roskosch
- Wittmann Andreas

Password*

.....

 Password is too weak

Password strength



Only use numbers, letters and these special characters :!@#\$%^&*()_+=[]{}';: ",./?

Confirm password*

Password strength: Weak

Use at least 8 characters. Don't use a password from another site, or something too obvious like your pet's name. [Why?](#)

Create a password

.....|

Confirm your password

Choose a password

.....



 This is a very common password. Choose something that will be harder for others to guess.

Wish

aim=e1Ioci	Ohyoh>wae0	kei7Gae\$si	bei3coo<Li	ooB,iu9AhN	Phei0IeHa'	uhu;j5ohTi
Phi,Phu3di	Moo0ooz"oh	we(u,t0Zas	quucoo<d2I	Pae?gh<ie3	loh;Bah4ei	Wa[el~oh9i
ooh!ee7Aik	AX1aeSh>ai	eGah+K5iuM	yae\$V4leex	ohjiu_Hei6	fee'Cho5Oo	jahK3Ad+ai
oH)eewaec0	KiG&ee4ahy	ujohj%ie1J	wae,Gei6mu	uSh=i2ahng	ainai]Le2i	Ieb~o5fohF
ohN\ah1gae	Dooch\ei7i	ich]a're1U	aiToh5cee=	eiZ2thaip;	ni"W3oom?i	oi(Sh7vie)
gu}i8Tohco	il@ah@ve9U	cie"tae8Eo	Au&S3aigae	eir0ieHo)c	ohch/ah6Ii	Bie*t9xie"
ukieTh6fu[	ie*vieZai9	ohwu(v0eeY	ua&ghi7aeR	em?ohG?oi3	phu\$L^ah4p	ieX&i2shei
aiZie%17Oo	ood8Pe<emo	faiGh[ie0i	OPho9sie>n	phie9Ib(ie	beiMei[r7a	Nagh(aid0U
AhTee:tah5	oY"a5pheib	ohthe1Na.e	eria9Ahn>u	eid8Ohso!o	Uv4ia6Gu`o	Aeli1lli\$i&
Toth^ai8ph	Euso6eu\$ja	vie8Ieh?ai	leec4aeZ/o	Eele+ph2na	yai=b!a5Oo	Wefoh&m4oh
Vo-oX9ka0v	ei9eenuN<a	Eit}ae4ohF	heRie.J6Bo	OoZ-ue9mai	zait8coo]N	yoh9Oopoh\$
xoh%C:ahk6	Zi]opu4eiB	eGh>ih2oPh	noo7Ish'ie	Uaz6she Zu	oo0aiP*ee2	coh=Puo1Ve
roo9Kee-th	ra@c3Ce7sh	mabi6Malo[	auw1Eu\kie	eiVoo,Kuu5	aiW\oo5phu	Oos_abir7U

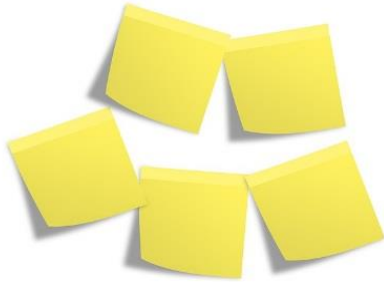
Your New Password:

X3#RsT[7UE2d&S^r

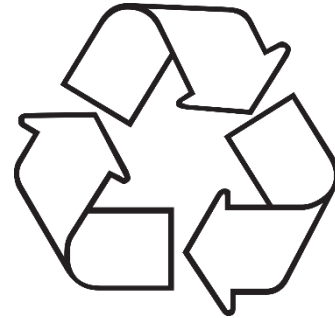
Remember your password:

XBOX 3 # ROPE skype TOKYO [7 USA EGG 2 drip & SKYPE ^ rope

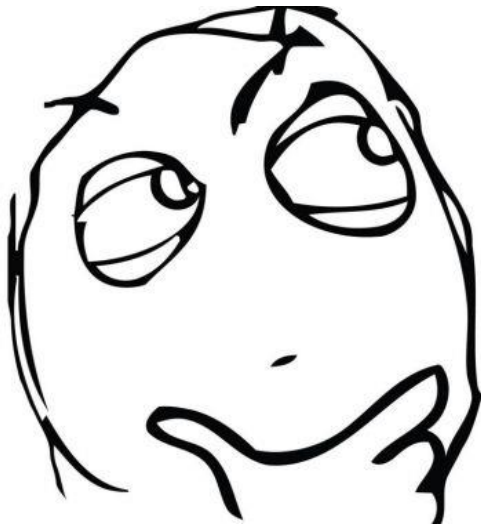
Reality



Note



Password-Recycling



Password-Manager

App	GooglePlay Downloads
Keeper	10 – 50 m
Keepsafe	10 – 50 m
1Password	1 – 5 m
Dashlane	1 – 5 m
Lastpass	1 – 5 m
Avast	0.5 – 1 m
MyPasswords	0.5 – 1 m
F-Secure	100 – 500 k
PasswordManger	50 – 100 k

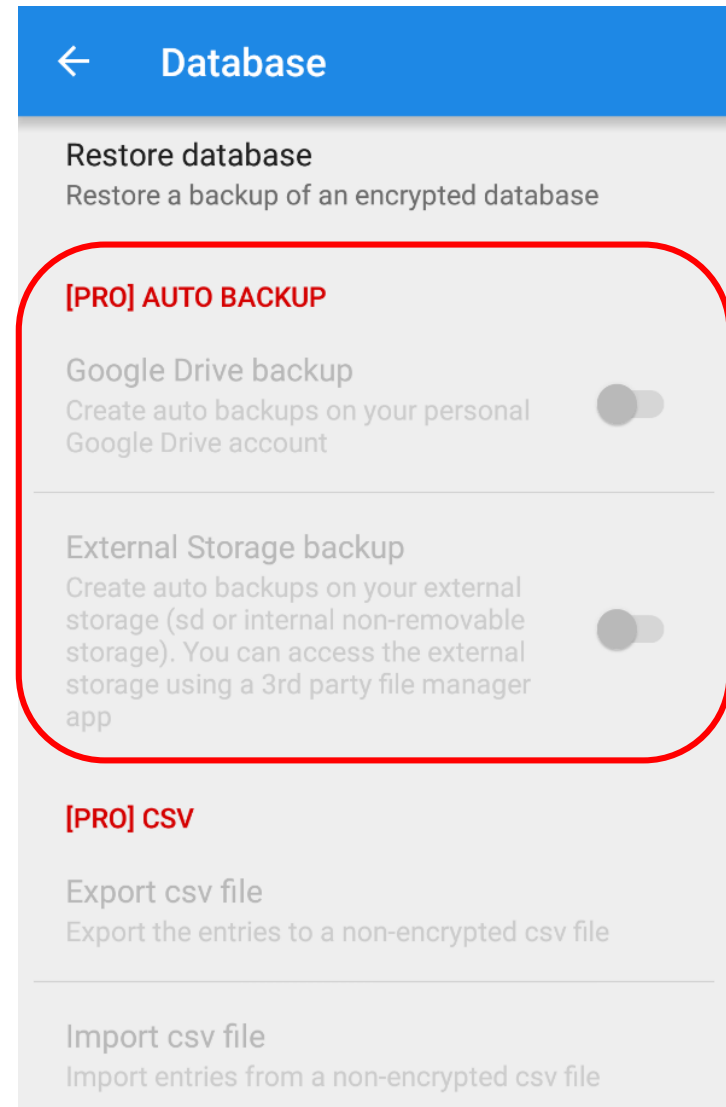
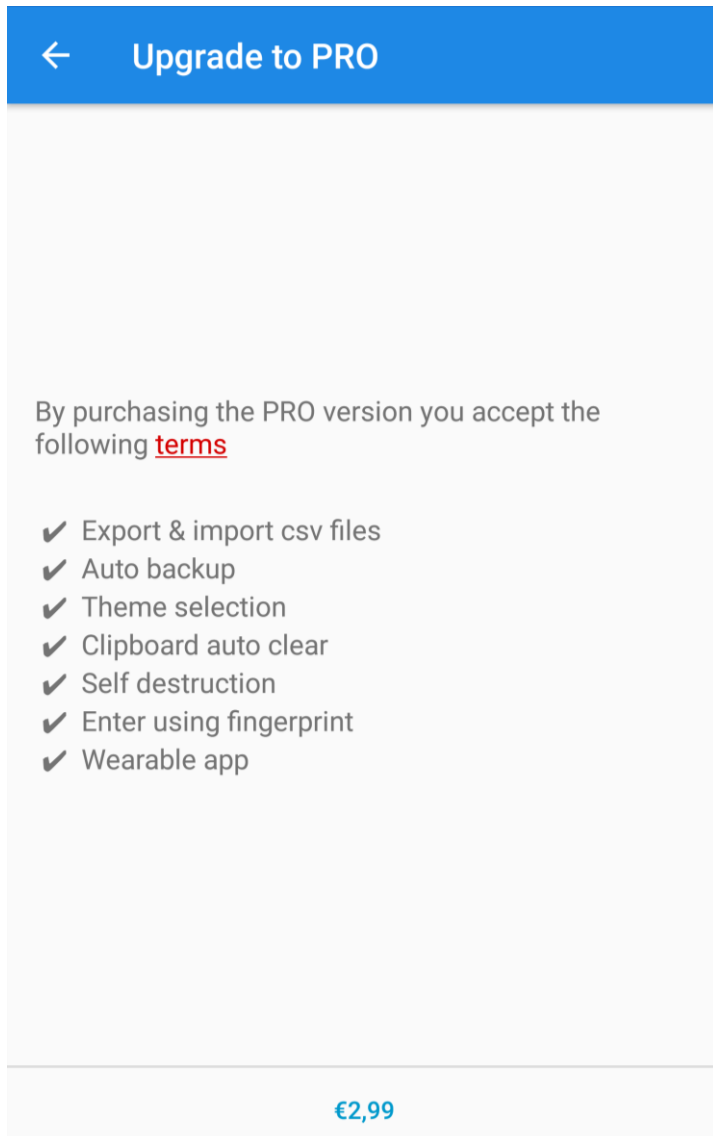
26 Vulnerabilities



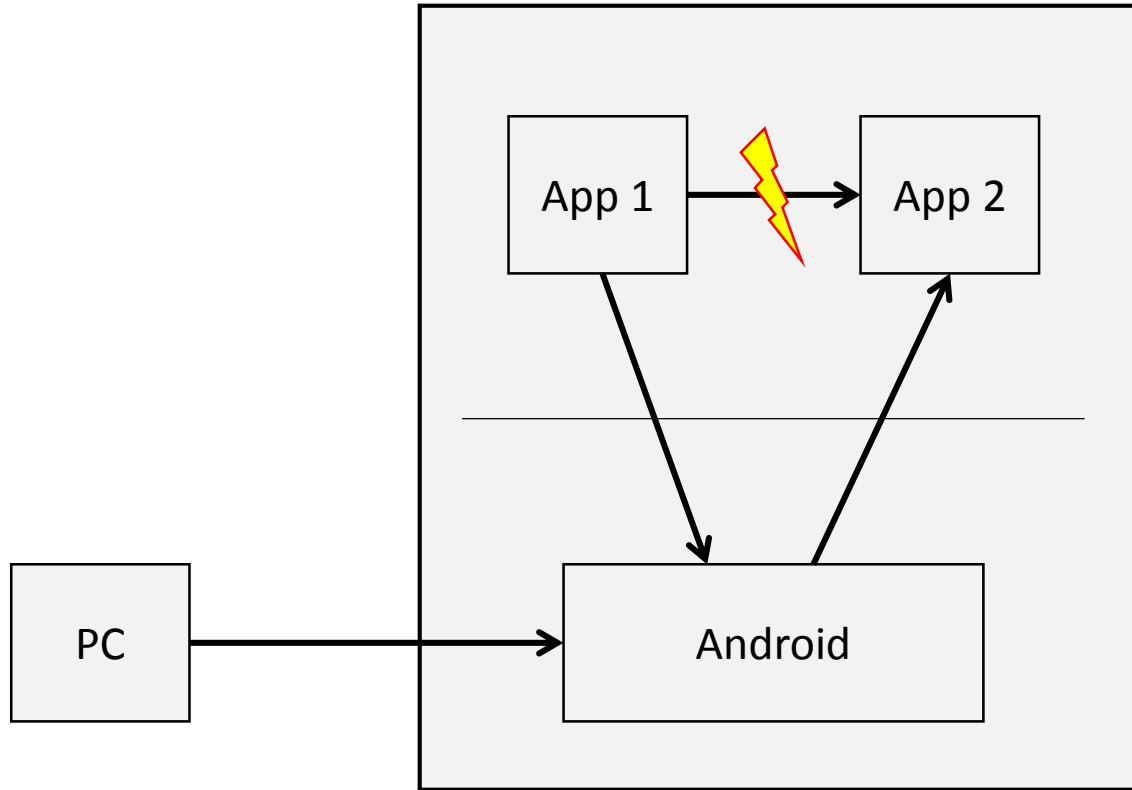
- Premium features for free
- Resetting master password with ease
- Breaking C.I.A **without ROOT**
 - Lost device scenario
 - Mitm attack
 - Via third party app



Premium upgrade for free !



Intent Communication (IPC)



```

class DatabaseSettings {

    protected static boolean PAID = false;

    protected void onCreate(Bundle bundle) {
        ...
        if (getIntent().getIntentExtra("PAID-STATUS", 0) == 2) {
            PAID = true;
        }
        ...
    }

    public void onActivityCreated(Bundle bundle) {
        ...
        checkBoxForBackup.setEnabled(PAID);
        ...
    }

}

```

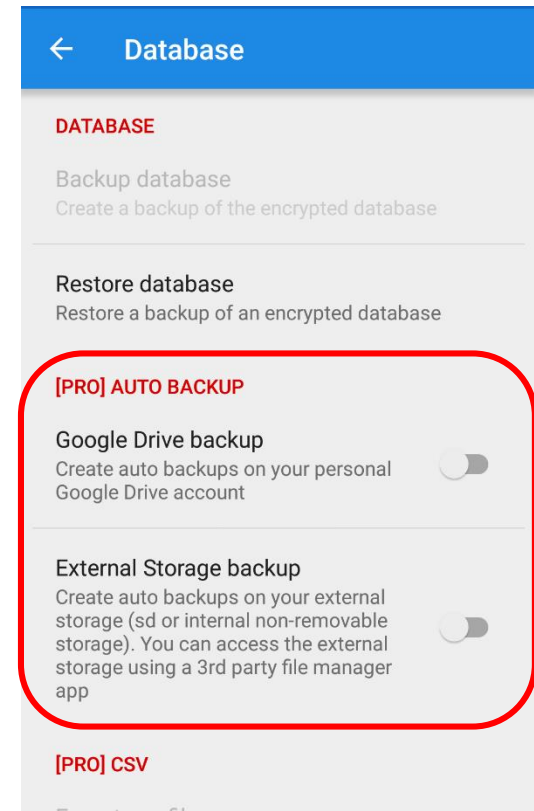
```

adb shell am start -n <package-
name>/DatabaseSettings -ei
PAID-STATUS 2

```

PC

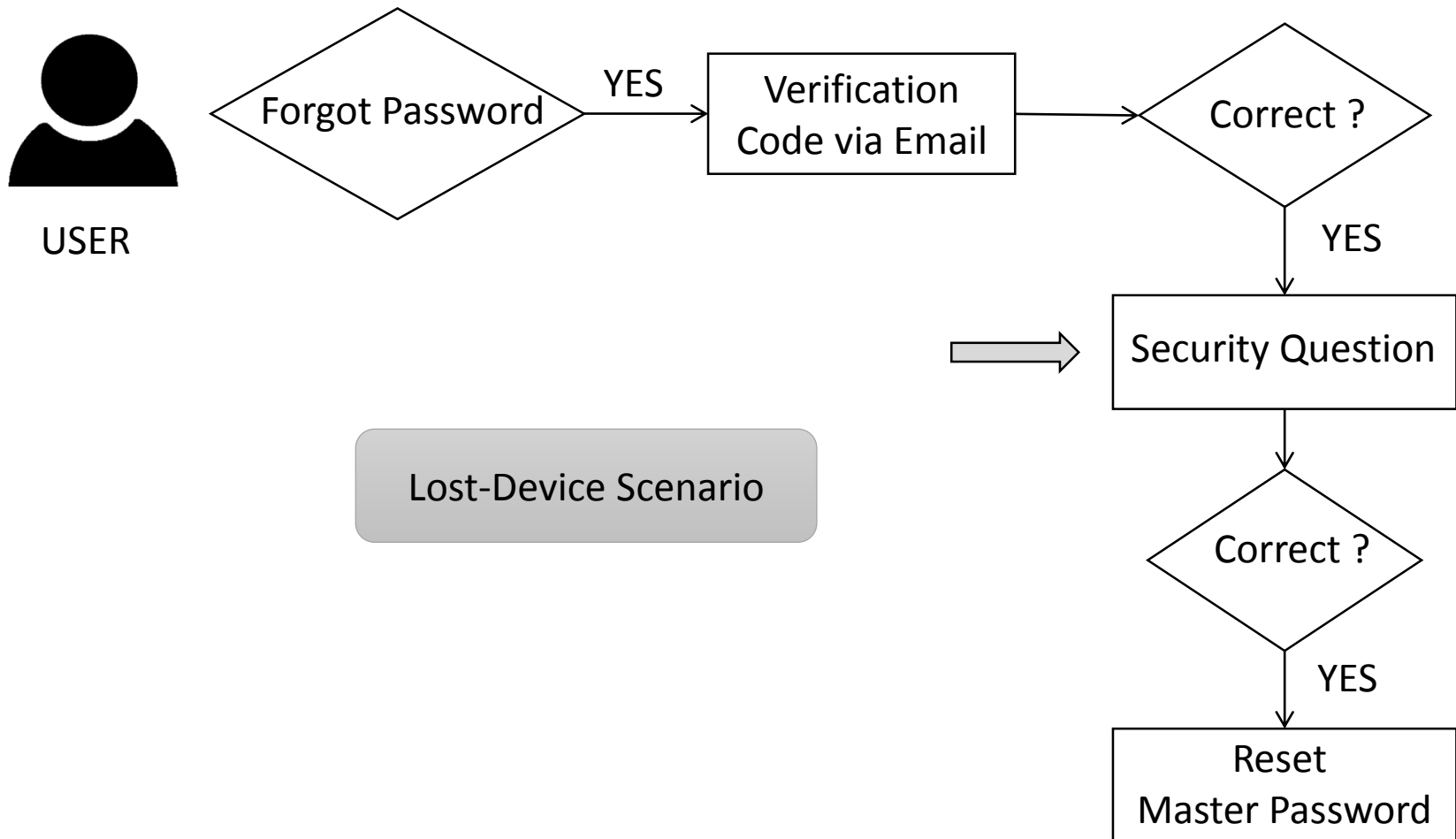
Android





Resetting Master Password

Common Password Reset Process

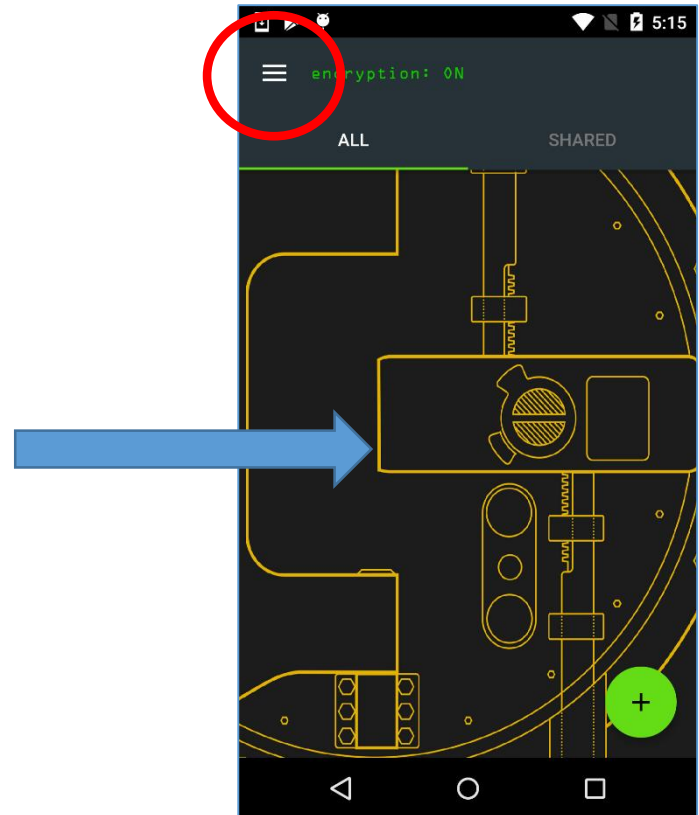


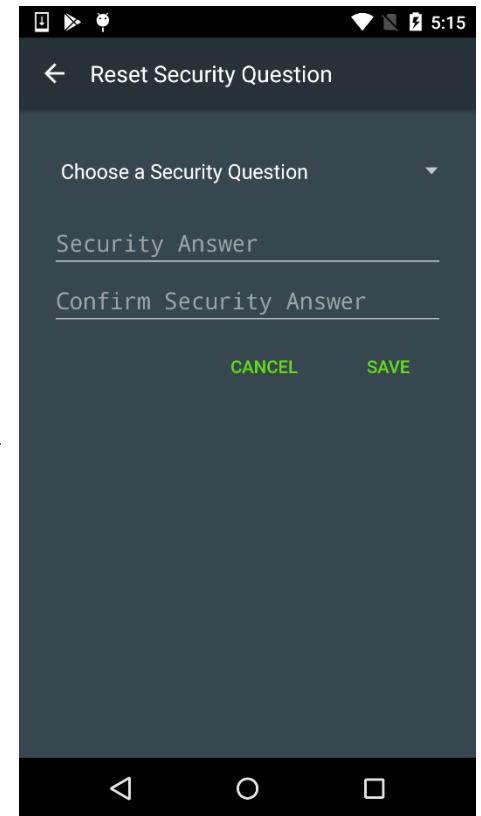
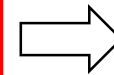
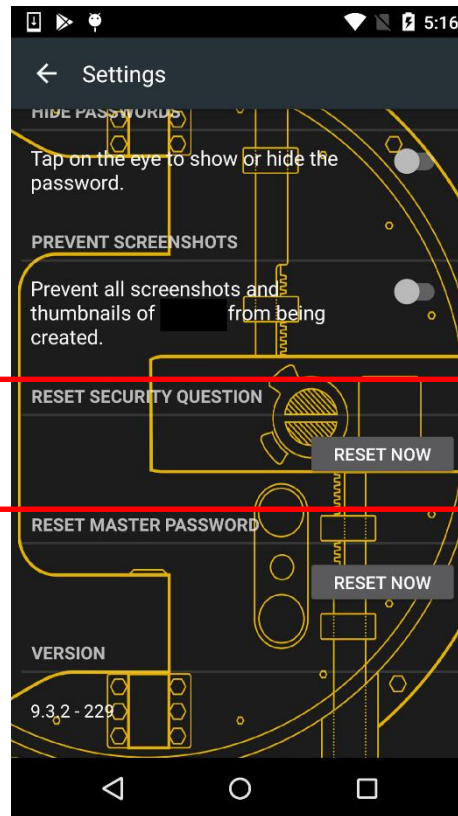
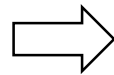
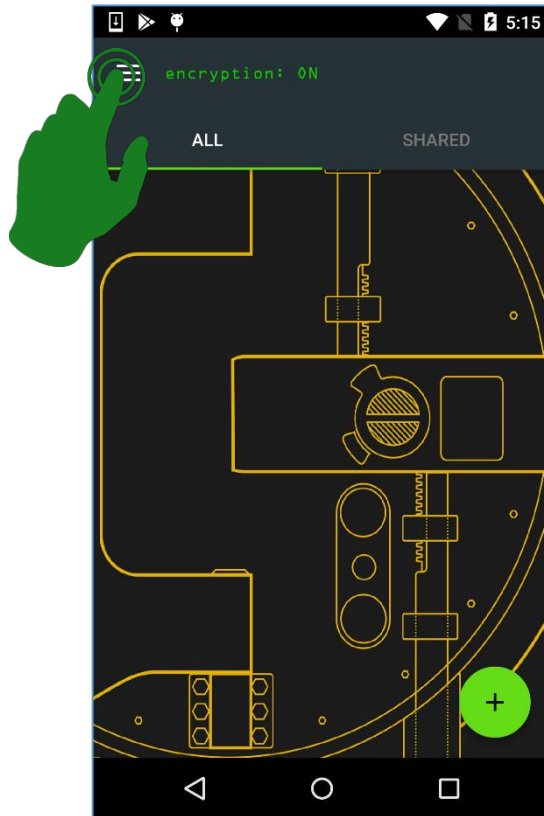
Manifest:

```
<activity android:theme="@*android:style/Theme.NoDisplay"
  android:label="@afk/app_name"
  android:name="com.xyz.android_apps.noname.DeepLinkActivity">
  <intent-filter>
    <action android:name="android.intent.action.VIEW" />
    <category android:name="android.intent.category.DEFAULT" />
    <category android:name="android.intent.category.BROWSABLE" />
    <data android:scheme="https" android:host="xyz.com" android:pathPattern="/*st.*" />
  </intent-filter>
</activity>
```

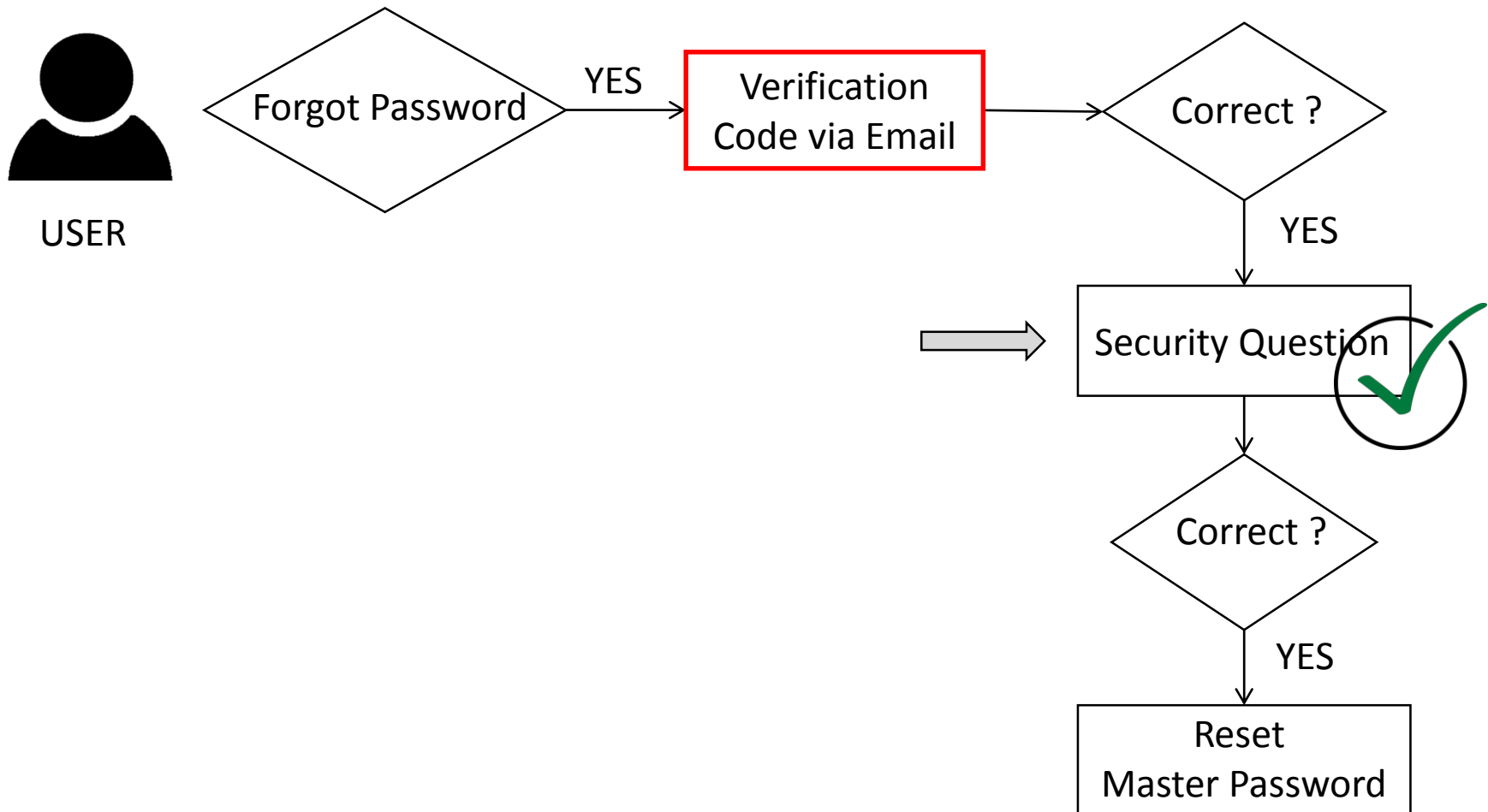
Start Activity:

```
adb shell am start -n
com.xyz.android_apps.noname/.Deep
pLinkActivity
```





Common Password Reset Process





Get Master Secret

Master Secret

1

Extraction process

- ADB-backup
- **Mitm attack**
- **Browser file access**
- **Residue attack**

2

Decryption process

- Plaintext
- **Custom crypto**
- **Hardcoded symmetric keys**
- **Custom obfuscation**

Master Secret

1

Extraction process

- ADB-backup
- **Mitm attack**
- Browser file access
- Residue attack

2

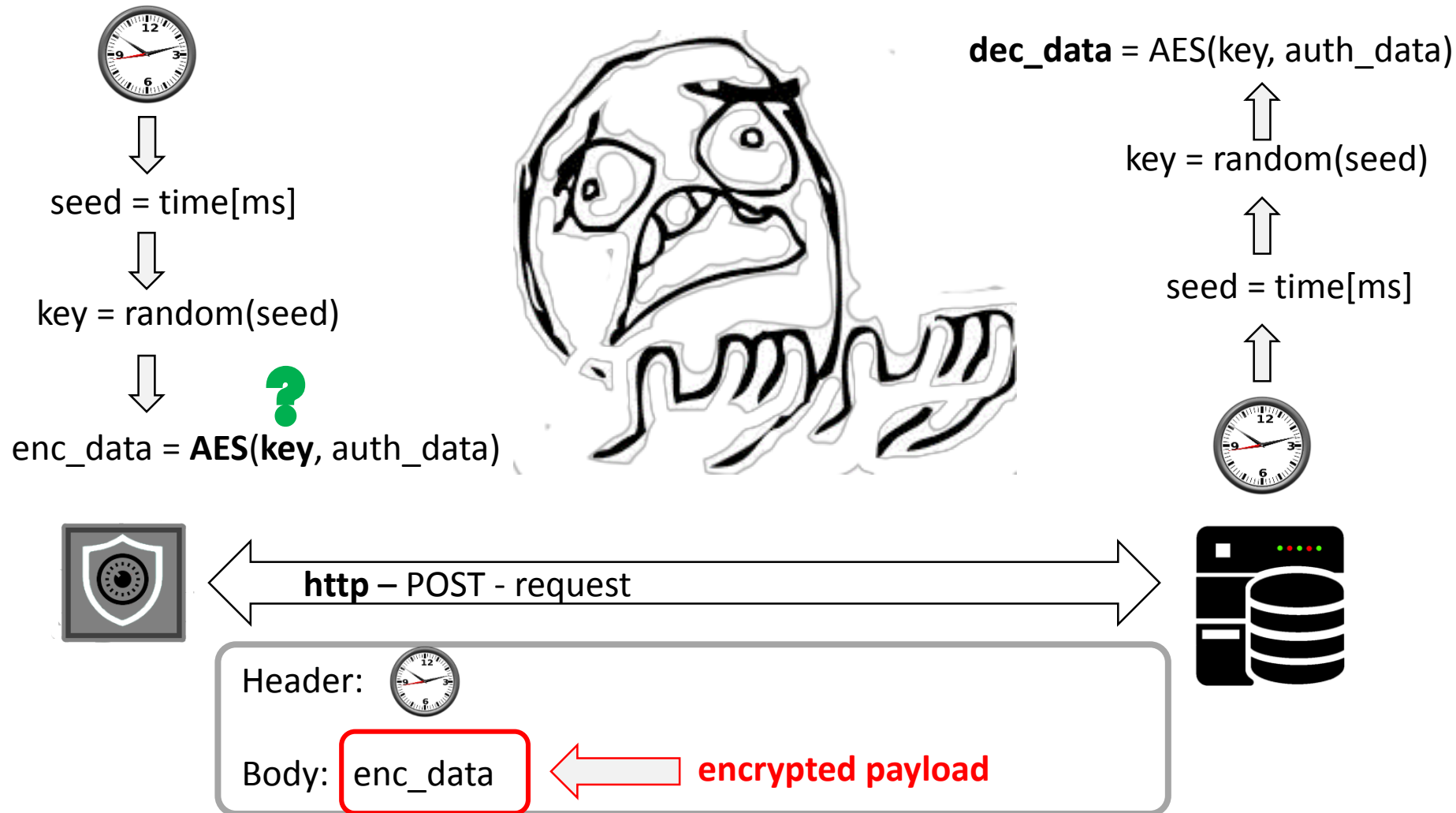
Decryption process

- Plaintext
- **Custom crypto**
- Hardcoded symmetric keys
- Custom obfuscation

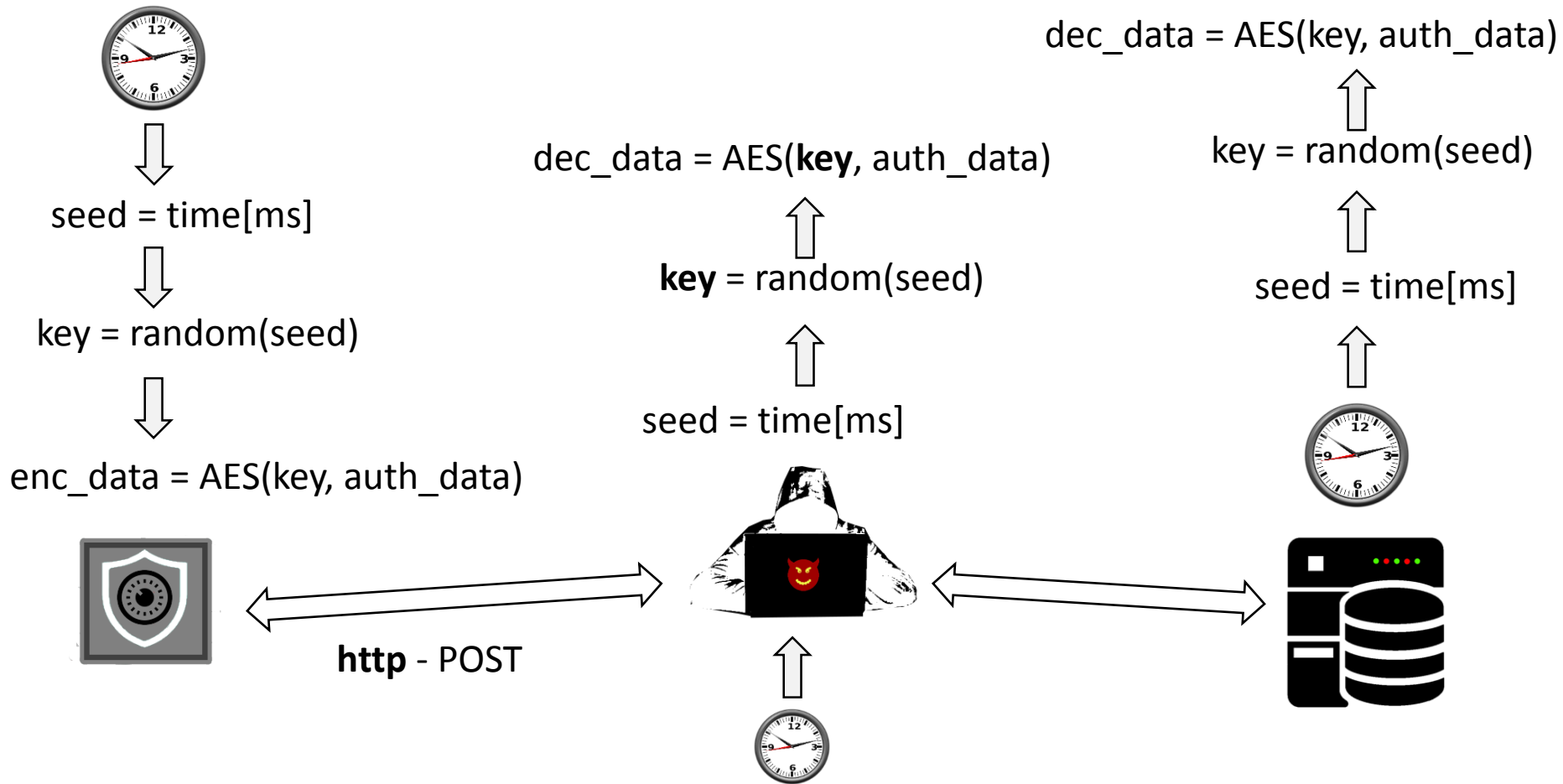
User Authentication



Authentication Process



Authentication Process



Best Practices: Secure Communication

- Android, correct SSL/TLS*

```
URL url = new URL("https://example.org");  
URLConnection urlConnection = url.openConnection();  
InputStream in = urlConnection.getInputStream();  
...
```

- Stronger, SSL/TLS (Pinning)
 - Android 7 supports pinning (security configuration file)
 - Use library with pinning support, e.g. OkHttp library (take care of version)

*<https://developer.android.com/training/articles/security-ssl.html>

Master Secret

1

Extraction process

- ADB-backup
- Mitm attack
- **Browser file access**
- Residue attack

2

Decryption process

- Plaintext
- Custom crypto
- Hardcoded symmetric keys
- Custom obfuscation



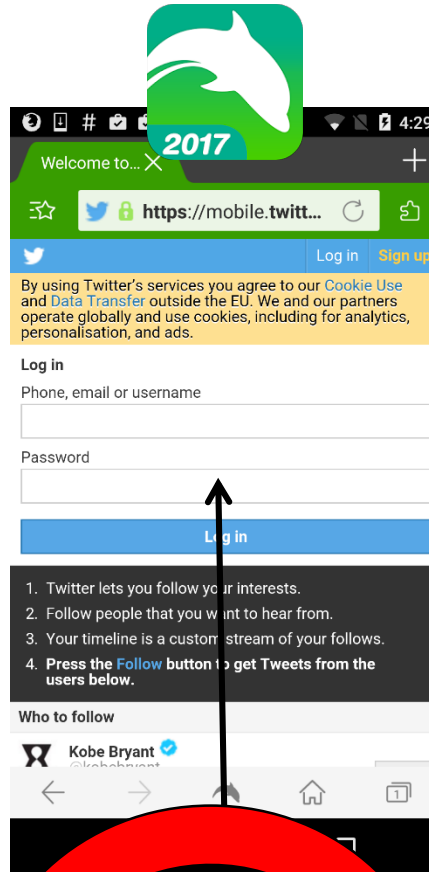
Log in to Twitter

Phone, email, or username

Password

Log in

[Forgot password?](#) · [Sign up for Twitter](#)



Log in

Phone, email or username

Password

Log in

1. Twitter lets you follow your interests.
2. Follow people that you want to hear from.
3. Your timeline is a custom stream of your follows.
4. Press the **Follow** button to get Tweets from the users below.

Who to follow

Kobe Bryant



Log in Sign up

By using Twitter's services you agree to our [Cookie Use](#) and [Data Transfer](#) outside the EU. We and our partners operate globally and use cookies, including for analytics, personalisation, and ads.

Log in

Phone, email or username

Password

Log in

1. Twitter lets you follow your interests.
2. Follow people that you want to hear from.
3. Your timeline is a custom stream of your follows.
4. Press the **Follow** button to get Tweets from the users below.

Who to follow

DIE ZEIT

Ein neuer Blick aus @DIEZEIT: Diese

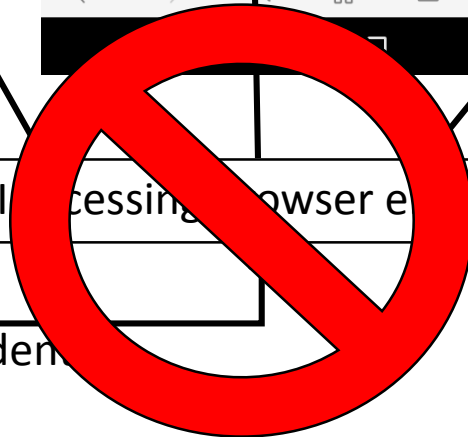


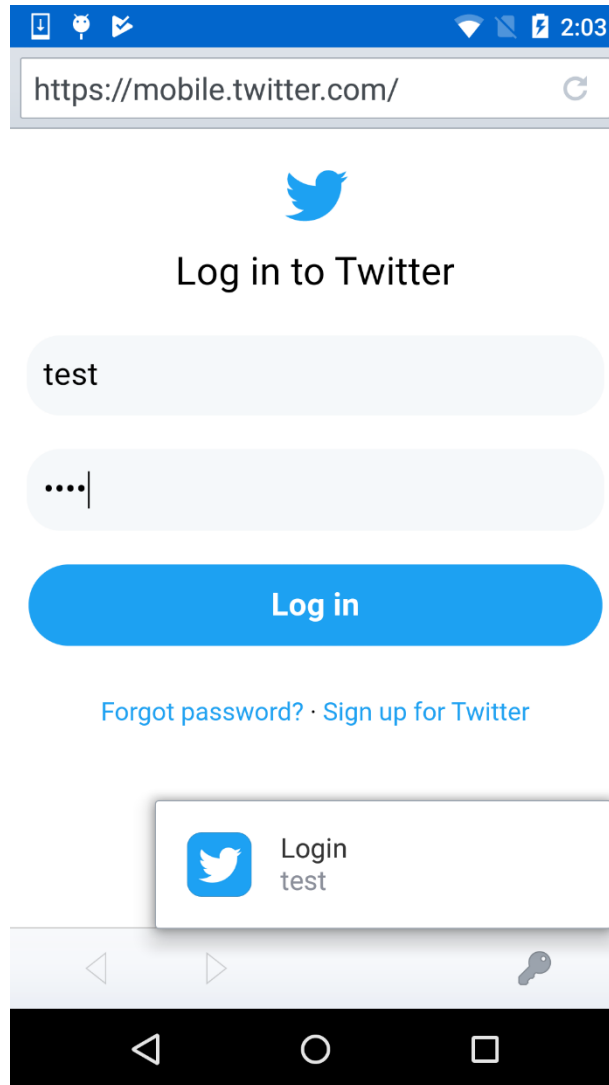
Pw Manager



API processing browser elements

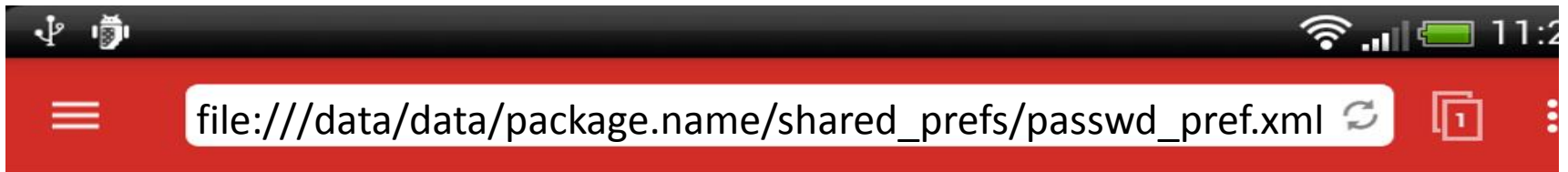
credentials





Inject

password manager process



This XML file does not appear to have any style information associated with it. The document tree is shown below.

```
▼<map>
  <string name="uid">104984802</string>
  <string name="showlaunchalert">1</string>
  <string name="dofastdecryption">1</string>
  <string name="loginpw">!CRpsShT82h9bfkoPprrtHA==|EbI41MyZXyI3XT1Yne4EoA==</string>
  <string name="allowoffline local">1</string>
  <string name="lastchallengenag_teamsiksm1@gmx.de">1470993329752</string>
```

base64(encr(key, PASS))

Master Secret

1

Extraction process

- ADB-backup
- **Mitm attack**
- Browser file access
- **Residue attack**

2

Decryption process

- Plaintext
- **Custom crypto**
- **Hardcoded symmetric keys**
- **Custom obfuscation**

THE ACCOUNTMANAGER



THE WHAT ?

Android AccountManger

- “This class provides access to a centralized registry for the user’s online accounts ...”
- SQLITE Database for storing tokens or temp. Credentials
- API provides access for Application

```
/data/system/users/0 # ls -l accounts.db  
-rw-rw---- system system      241664 2017-04-03 10:58 accounts.db
```


*“With this in mind, you **shouldn't pass the user's actual password** to `AccountManager.addAccountExplicitly()` . Instead, you should store a cryptographically **secure token** that would be of limited use to an attacker.*

If your user credentials are protecting something valuable, you should carefully consider doing something similar.”

Quote google developer (AccountManager)

https://developer.android.com/training/id-auth/custom_auth.html



DEMO TIME !



ID	email	type	token



account type



Target App



com.account

email@mail.com

secret

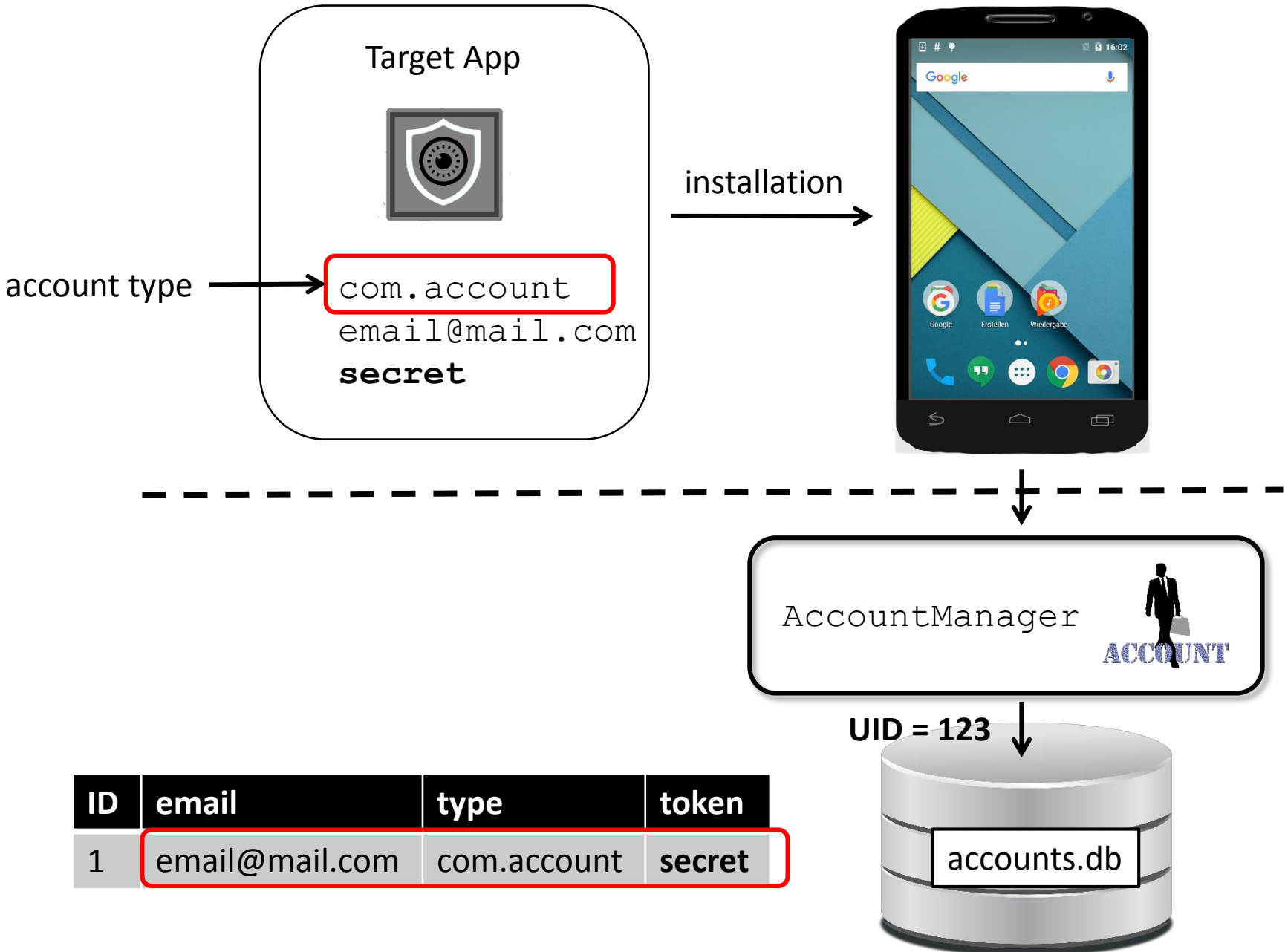


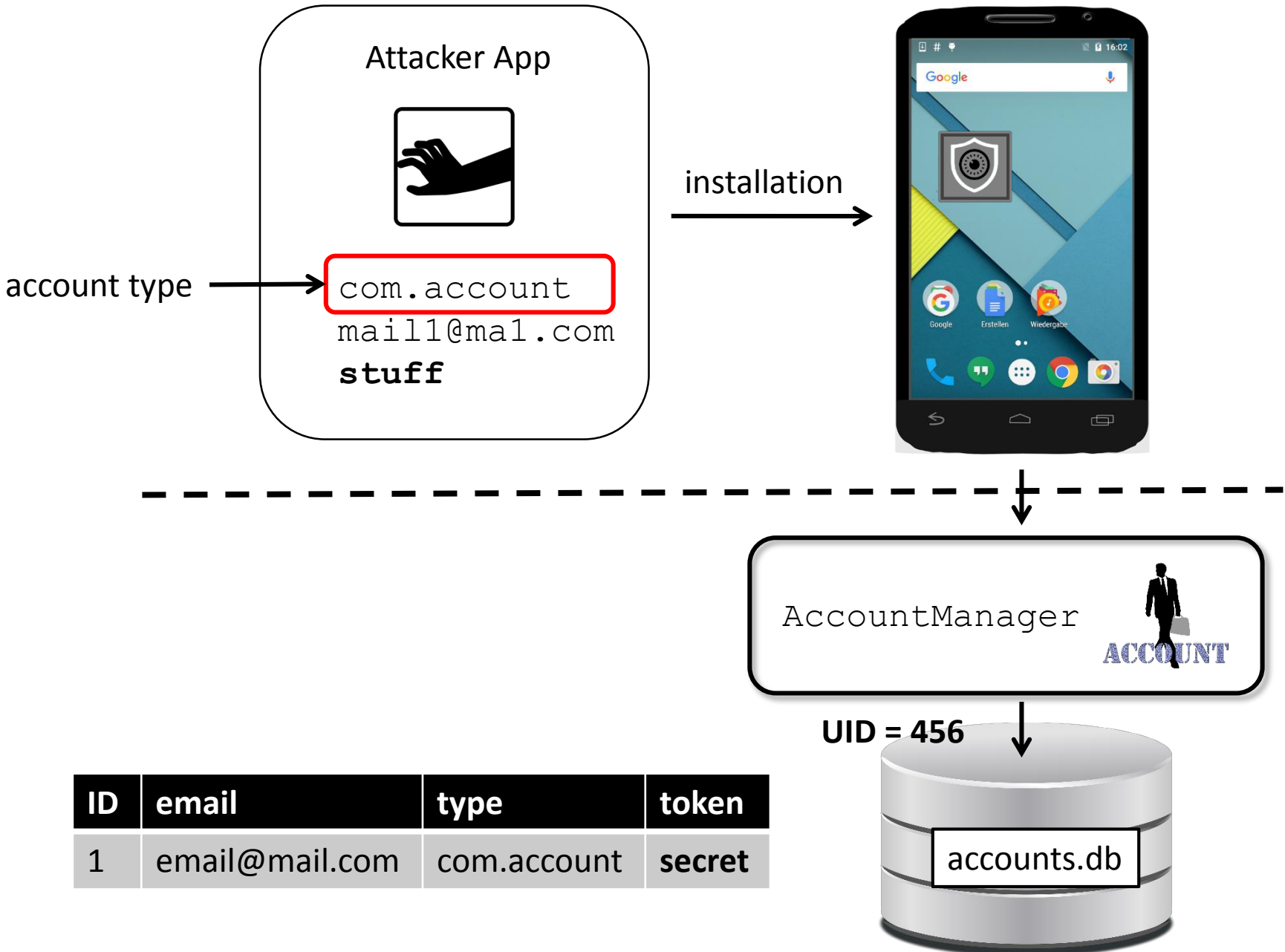
AccountManager

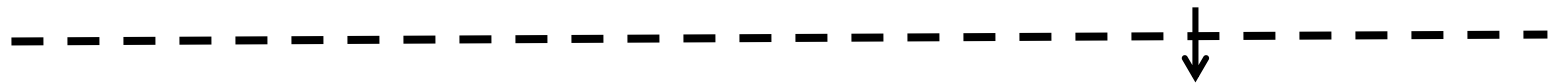
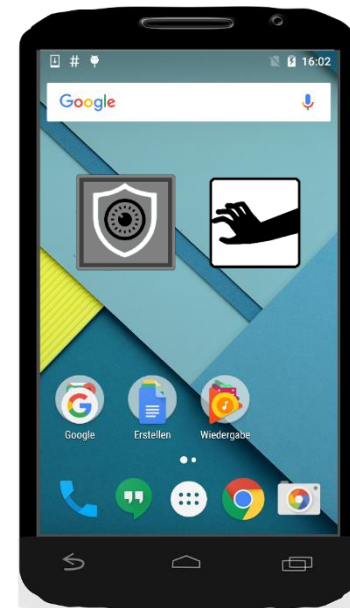


ID	email	type	token









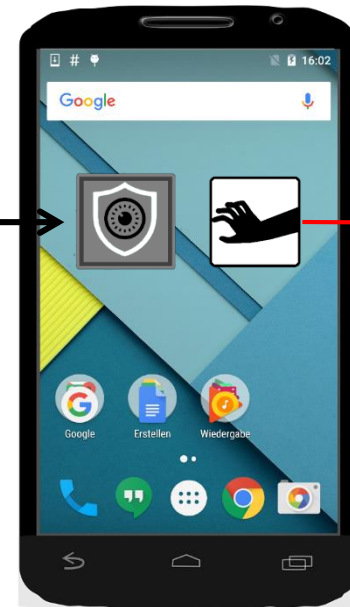
COLLISION !
UID:123 $\neq$ UID:456



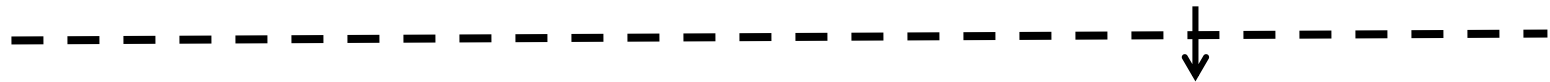
ID	email	type	token
1	email@mail.com	com.account	secret



uninstall target app



com.account



AccountManager

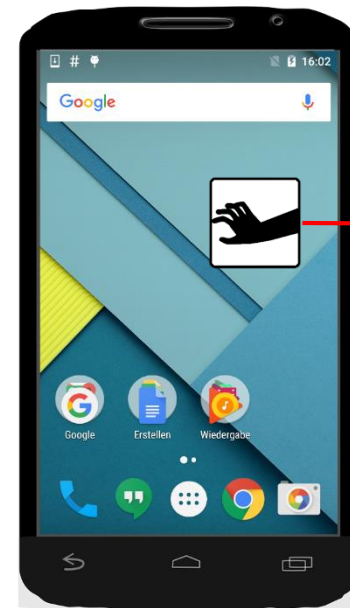


COLLISION !
UID:123 $\neq$ UID:456



ID	email	type	token
1	email@mail.com	com.account	secret

accounts.db



com.account



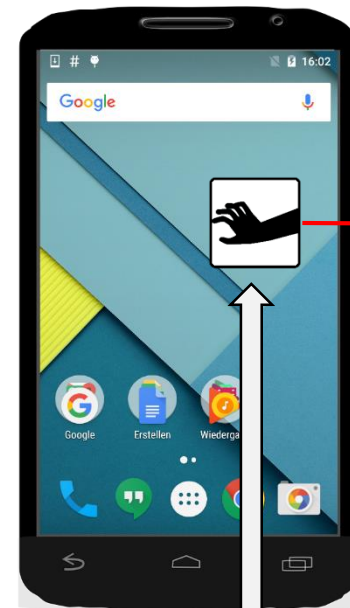
Not removed,
there is an app with matching account type



ID	email	type	token
1	email@mail.com	com.account	secret



Attacker app can now access the secret !



com.account

AccountManager



ID	email	type	token
1	email@mail.com	com.account	secret

accounts.db

Master Secret

1

Extraction process

- ADB-backup
- **Mitm attack**
- **Browser file access**
- **Residue attack**

2

Decryption process

- Plaintext
- **Custom crypto**
- **Hardcoded symmetric keys**
- **Custom obfuscation**

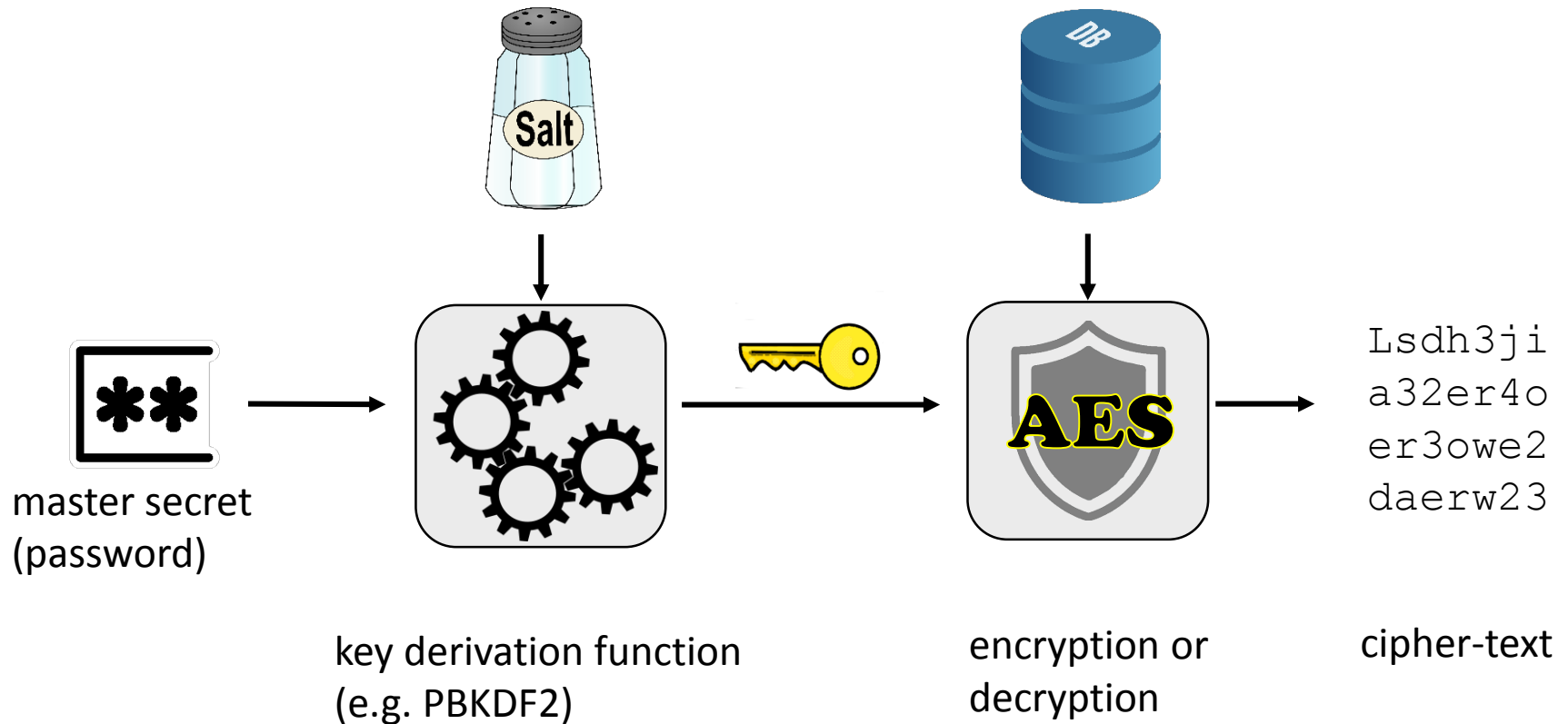
Crypto – Do it right

Kerckhoffs's principle

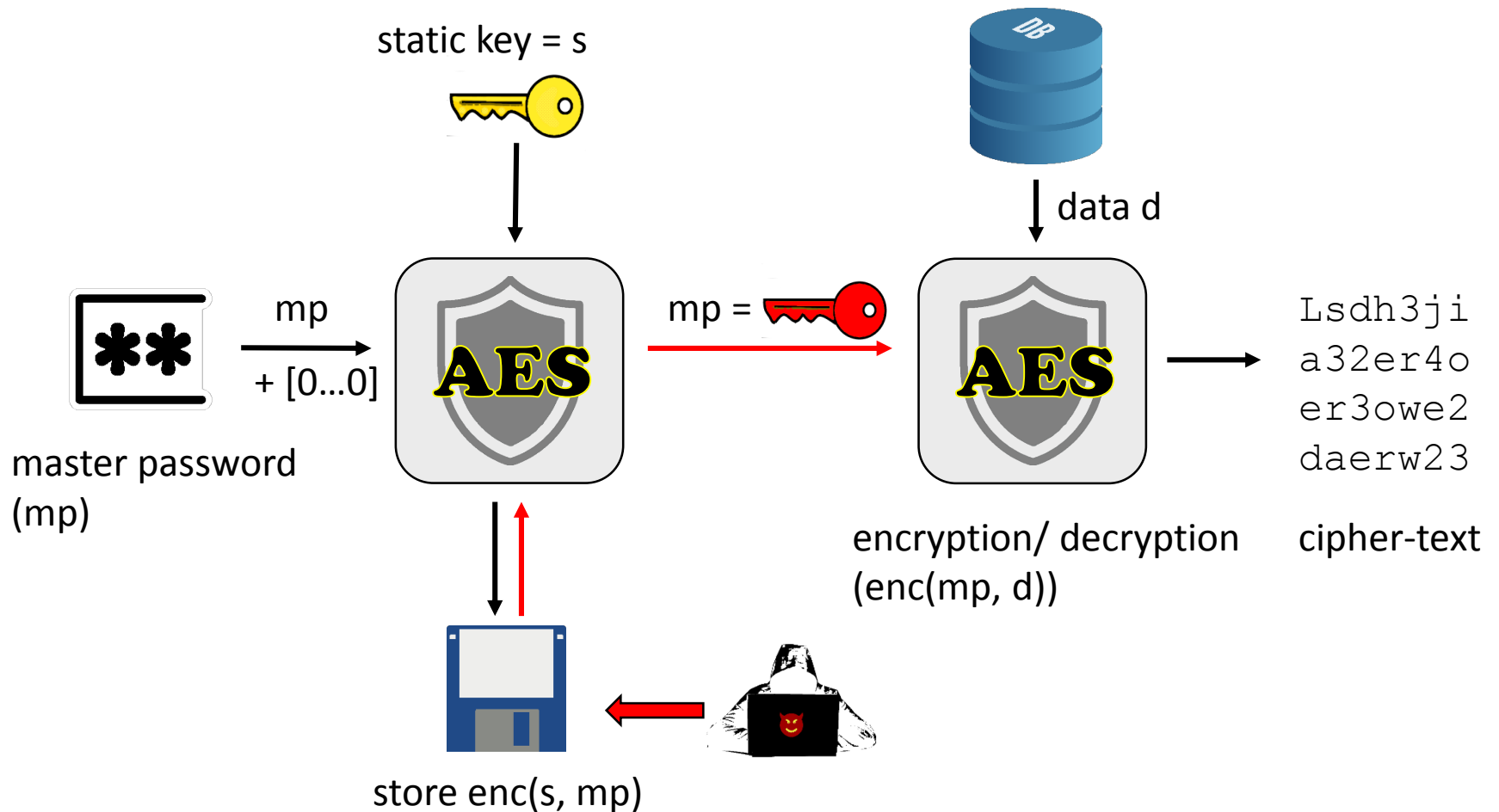
“A cryptosystem should be secure even if everything about the system, except the key, is public knowledge.” *

*JOURNAL DES SCIENCES MILITAIRES. Janvier 1883. LA CRYPTOGRAPHIE MILITAIRE.

Correct encryption



Bad Crypto



Hard-coded keys

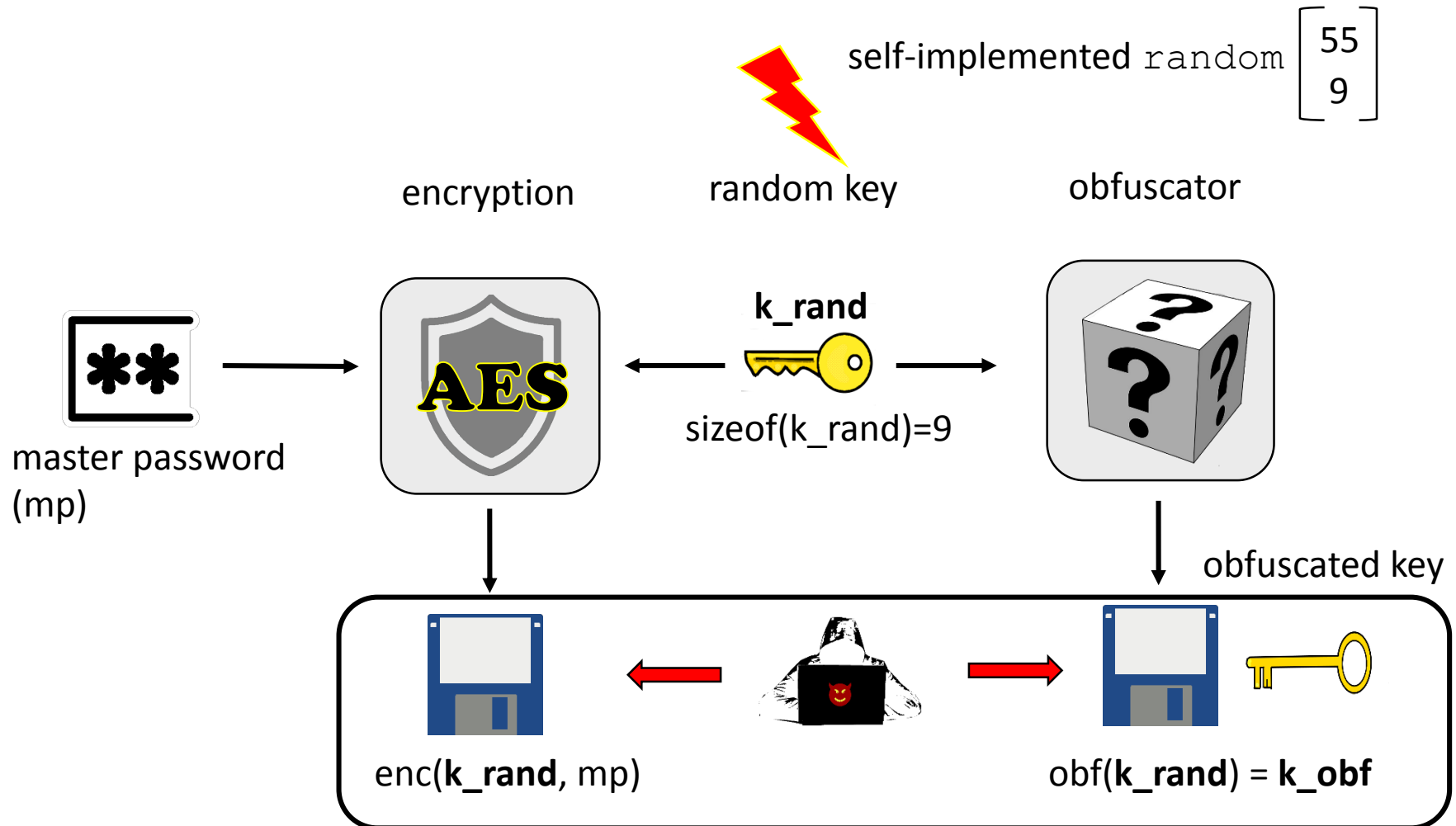
```
String = staticinvoke f.b("ydPCPFnpqfPuuBYPzhfGXD38gtUPN2yj",  
$String);
```

AES-Key = ydPCPFnpqfPuuBYPzhfGXD38gtUPN2yj

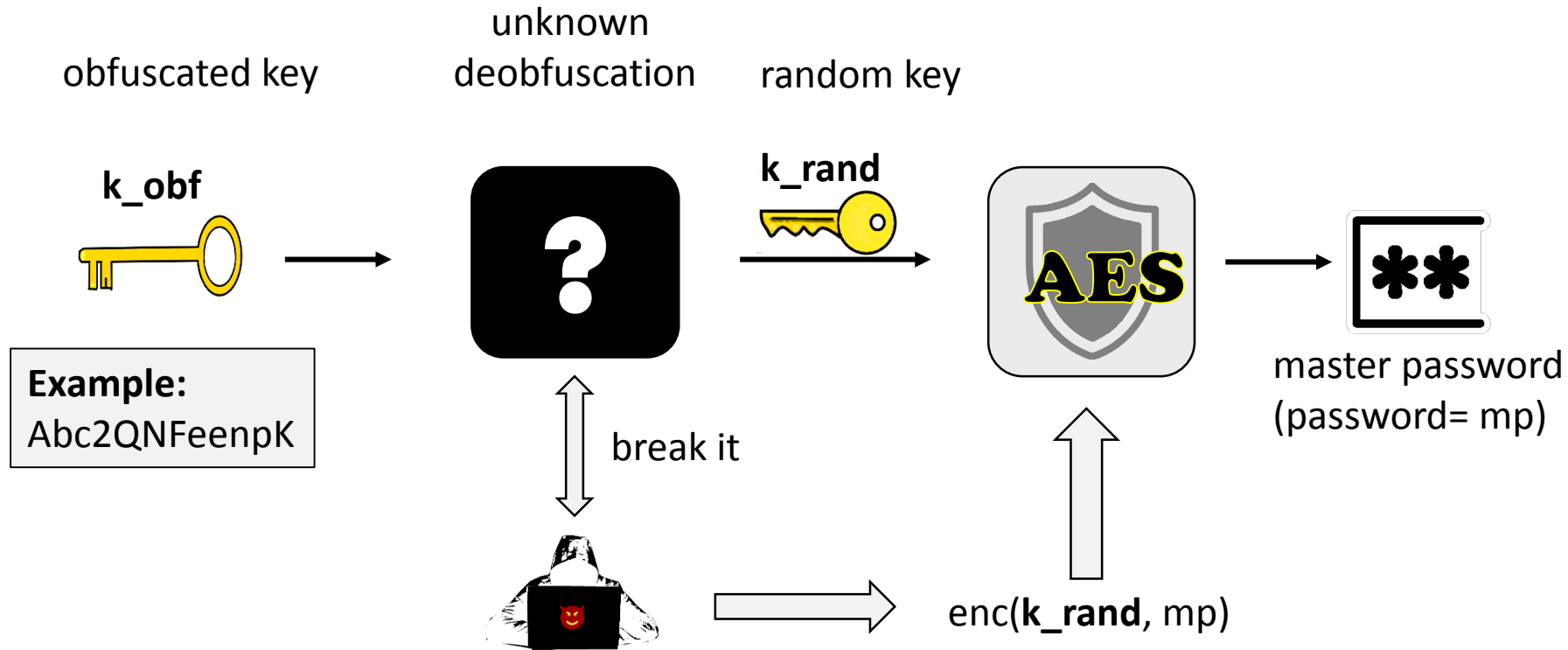
```
public abstract class LPCommon {  
    //first part of the key  
    protected static String aA = "ldT52Fjsnjdn4390";  
    //second part of the key  
    protected static String aB = "89y23489h989fFFF";
```

AES-Key = ldT52Fjsnjdn4390 89y23489h989fFFF;

Broken Key Obfuscation

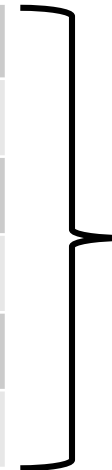


Break Obfuscation

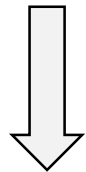


Key Obfuscation Analysis

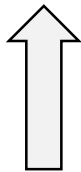
k_random parts	k_obfuscated pos	k_obf parts
k[0] + k[1]	[0-2]	Abc
k[2]	3	2
k[3] + k[4]	[4-6]	QNF
k[5]	7	e
k[6] + k[7]	[8-11]	enp
k[8]	12	K



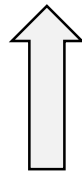
independent



reverse lookup table

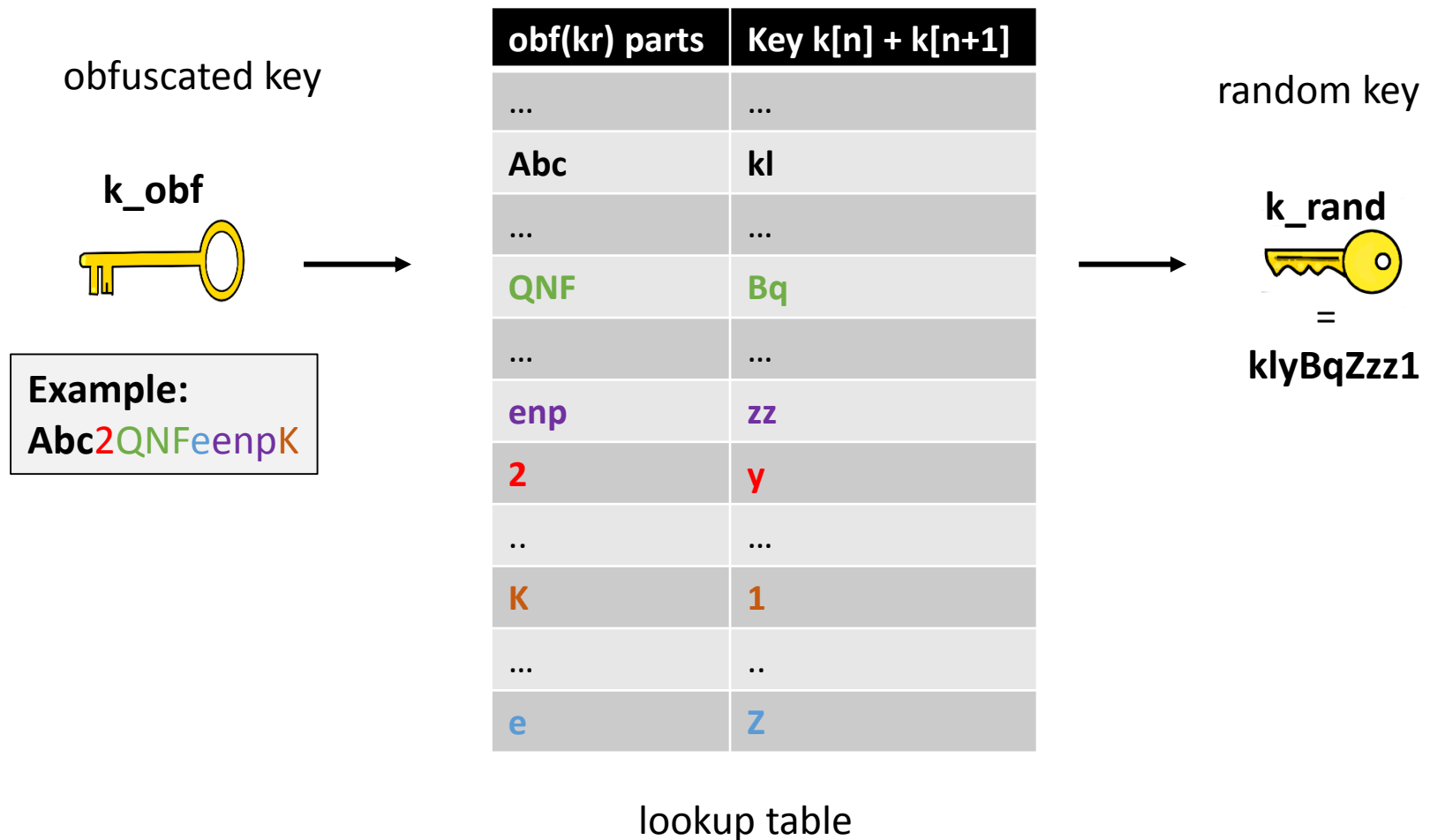


modified



changes

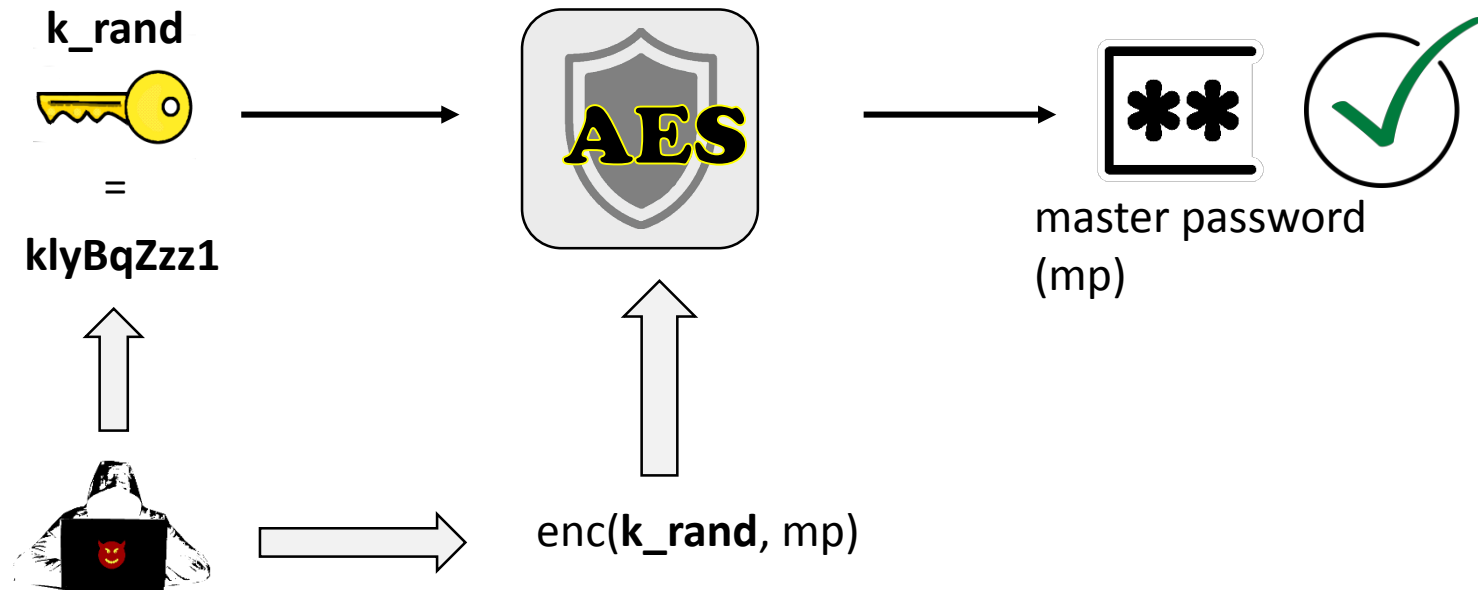
Reverse Lookup



Decrypt Master Password

random key

decryption



Recommendations (1/2)

- Use Android **KeyStore**
- Key derivation (e.g. **PBKDF2 (API)**, **Conceal (Open Source, bcrypt, ...)**)
- No **static keys**
- Use **AES/CBC** or **AES/GCM**

Recommendations (2/2)

- Disable **backup flag** (apps support backend synchronization -> implicit backup)
- If there is a master pass storage function, **do not** store it in **plaintext**
- **Do not** store the **master pass** in the **local app folder**, this is not a protected area

	Keeper	Lastp	1Pass	MyPass	Avast	F-Sec	Keeps.	PwMgr	Mirsoft	Dash
Master/PIN	X	X		X		X	X	X	X	X
Hardcoded Key		X		X					X	X
Sandbox Bypass		X	X	X					X	X
Side channel		X	X	X	X					X
Subdomain		X	X		X	X		X		X
Data leakage		X	X							X
Partial encryption			X							
Broken sync.					X					

www.sit4.me/pw-manager

aim=e1Ioci	Ohych>wae0	kei7Gae\$si	bei3coo<Li	ooB,iu9AhN	Phei0IeHa'	uhu;j5ohTi
Phi,Phu3di	Moo0ooz>oh	we(u,t0Zas	quucoo<d2I	Pae?gh<ie3	loh;Bah4ei	Wa[el~oh9i
ooh!ee7Aik	AXlAeSh>ai	eGah+K5iuM	yae\$V4leex	ohjiu Hei6	fee'Cho5Oo	jahK3Ad+ai
oH)eewaec0	KiG&ee4ahy	ujohj%ielJ	wae,Gei6mu	uSh=i2ahng	ainai]Le2i	Ieb~o5fohF
ohN\ahlgae	Dooch\ei7i	ichja'relU	aiToh5cee=	eiZ2thaip;	ni"W3oom?i	oi(Sh7vie)
qu}i8Tohco	il@ah@ve9U	cie"tae8EO	Au&S3aigae	eir0ieHo)c	ohch/ah6Ii	Bie*t9xie"
ukieTh6fu[	ie*vieZai9	ohwu(v0eeY	ua&ghi7aeR	em?ohG?oi3	phu\$L^ah4p	ieX&i2shei
aiZie%17Oo	ood8Pe<emo	faiGh[ie0i	OPho9sie>n	phie9Ib(ie	beiMei[r7a	Naqh(aid0U
AhTee:tah5	oY"a5pheib	ohthe1Na.e	eria9Ahn>u	eid8Ohso!o	Uv4ia6Gu`o	AeliilliSi&
Toth^ai8ph	Euso6eu\$ja	vie8Ieh?ai	leec4aeZ/o	Eele+ph2na	yai=b!a5Oo	Wefoh&m4oh
Vo~oX9ka0v	ei9eenuN<a	Eit)ae4ohF	heRie.J6Bo	OoZ~ue9mai	zait8ccoo]N	yoh9Oopoh\$
xoh%C:ahk6	Zi]opu4eiB	eGh>ih2oPh	noo7Ish'ie	Uaz6she Zu	oo0aiP*ee2	coh=Puo1Ve
roo9Kee~th	ra@c3Ce7sh	mabi6Malo[	auw1Eu\kie	eiVoo,Kuu5	aiW\oo5phu	Oos_abir7U

Your New Password:

X3#RsT[7UE2d&S^r

Remember your password:

XBOX 3 # ROPE skype TOKYO [7 USA EGG 2 drip & SKYPE ^ rope



- Premium features for free
- Resetting master password with ease
- Breaking C.I.A **without ROOT**
 - Lost device scenario
 - Mitm attack
 - Via third party app

Recommendations (1/2)

- Use Android **KeyStore**
- Key derivation (e.g. **PBKDF2 (API)**, **Conceal (Open Source, bcrypt, ...)**)
- No **static keys**
- Use **AES/CBC** or **AES/GCM**

	Keeper	Lastp	1Pass	MyPass	Avast	F-Sec	Keeps.	PwMgr	Mirsoft	Dash
Master/PIN	X	X		X		X	X	X	X	X
Hardcoded Key		X		X					X	X
Sandbox Bypass		X	X	X					X	X
Side channel		X	X	X	X					X
Subdomain		X	X		X	X		X		X
Data leakage		X	X							X
Partial encryption			X							
Broken sync.					X					

www.sit4.me/pw-manager

THIS IS THE END



MY FRIEND

team [SIK]

Stephan Huber

Email: stephan.huber@sit.fraunhofer.de

Siegfried Rasthofer

Email: siegfried.rasthofer@sit.fraunhofer.de

Twitter: @teamsik

Website: www.team-sik.org